Humans – The weakest link

STUDY PROJECT 2

JOHN LIEN

Course code	FS2SP2131
Course title	Study project 2
Assignment title	Humans – The weakest link
Date	10.11-2023

JSL

Contents

IT-terms handbook 2
Introduction 4
Main part 6
What is Social Engineering? 6
History 8
Most common social engineering attacks and techniques 10
1. **Phishing** 10
2. **Whaling** 10
3. **Baiting** 11
4. **Diversion Theft** 12
5. **Business Email Compromise (BEC)** 12
6. **Smishing/SMS-phishing** 13
7. **Quid Pro Quo** 13
8. **Pretexting** 14
9. **Honeytrap** 14
10. **Tailgating/Piggybacking** 15
Attacks 16
Attacks and platforms 16
Motivation 18
Personal vs business 20
Personal 20
Business 22
Practical demonstration 27
QR Code phishing attack 27
Credential Harvesting 31
Tailgating (physical) 33
Prevention 35
Conclusion 39
References 40

JSL

IT-terms handbook

This handbook is provided for you if you do not have the knowledge of some terms I refer to in my report. Advanced terms will be explained in the text, but this is a helpful tool if you do not have the expected knowledge mentioned in the introduction below. I will not refer to the handbook. Please return to it on your own accord if there are some terms you do not know the meaning of.

Term	Explanation
Social Engineering	"The act of deceiving an individual into revealing sensitive information, obtaining unauthorized access, or committing fraud by associating with the individual to gain confidence and trust (CSRC, *Social Engineering*)".
Malware	"Hardware, firmware, or software that is intentionally included or inserted in a system for a harmful purpose (CSRC, *Malware*)".
Ransomware	"Type of malware that prevents or limits users from accessing their system, either by locking the system's screen or by locking the users' files until a ransom is paid (TrendMicro, *Ransomware Definition*)".
Cryptocurrency	"Any form of currency that only exists digitally, that usually has no central issuing or regulating authority but instead uses a decentralized system to record transactions and manage the issuance of new units, and that relies on cryptography to prevent counterfeiting and fraudulent transactions (Marriam-Webster, *Cryptocurrency*)".
Multi Factor Authentication / MFA	"An authentication system that requires more than one distinct authentication factor for successful authentication. Multifactor authentication can be performed using a multifactor authenticator or by a combination of authenticators that provide different factors.

JSL

	The three authentication factors are something you know, something you have, and something you are (CSRC, *MFA*)”.
Lockbit ransomware	Operates as a Ransomware-as-a-Service model. Due to multiple unconnected attackers the tactics, techniques and patterns all vary. The varied attacks make it hard for police and organizations to protect themselves and investigate successful attacks. (*Understanding Ransomware Threat Actors: LockBit* 2023)
Managed Service Provider (MSP) / Managed Security Service Partner (MSSP)	“Third-party organizations that provide services to a company. However, these two types of service providers differ significantly in their focus. An MSP delivers general network and IT support, and services such as managed telecommunications (telco) or Software as a Service (SaaS) platforms. In contrast, an MSSP is focused solely on providing security services (Checkpoint, *What is a Managed Security Service Provider (MSSP)?*)”.

JSL

Introduction

During the last 40 years, the workforce has quickly become digital and online. This has happened extremely fast and everything we do on the internet leaves digital traces. Our jobs rely on digital and online solutions to effectively do our jobs. Many companies even store sensitive data in the cloud. Digital solutions are efficient and cost-effective but at what cost? We need security solutions everywhere because software and hardware have vulnerabilities. Humans create these solutions, and we have imperfections. There are people that will exploit these vulnerabilities and some of these vulnerabilities include exploiting each other's flaws socially. It does not matter how many security solutions that are set in place if one person can be tricked into bypassing them. This is called Social Engineering and is why we as humans are the weakest link.

In this report I will firstly go over what social engineering is, how it became so dangerous and effective. Secondly, I will go over common social engineering attacks and techniques, what damage it does, how it can affect businesses and persons in the same way. Third, I will go over how it generally and technically is done and real-world cases with actual damages. Lastly, I will go over how we can try to prevent it without having catastrophic damages done to your business and personal life. I will mostly cover the digital cybersecurity aspect of the topic. However, a physical attack could lead to a cyberattack so I will also cover a tiny bit of it.

In this report I will assume that you have basic knowledge of computers, operating systems, cybersecurity and physical security. The basic knowledge might be using digital solutions in day-to-day work, using Microsoft Word, printing, logging hours or manage financial information on a bank website. I will presume your business has internal IT-operations or is using a Managed Service Provider (MSP) / Managed Security Service Partner (MSSP) to deal with parts of IT or everything revolving around IT.

PSA: Please do not interact with any of the emails, phone numbers or websites I mention in the report, they could be dangerous and lead to phishing or information leaks. We are not to be held

accountable if anyone damages the organizations systems after reading this. The references are off course safe.

JSL

Main part

What is Social Engineering?

Social Engineering is defined by National Institute of Standards (NIST) as "The act of deceiving an individual into revealing sensitive information, obtaining unauthorized access, or committing fraud by associating with the individual to gain confidence and trust (CSRC, *Social Engineering*)". The European Union Agency for Cybersecurity's (enisa) definition on the subject is fairly similar: "Social engineering refers to all techniques aimed at talking a target into revealing specific information or performing a specific action for illegitimate reasons (ENISA, *What is "Social Engineering"?*)".

Social engineering is about deceiving individuals by various means and making them give out access to information you should not have access to. This information is often then abused nefariously. That is the "nice" description. A not so nice description is that social engineering is about using manipulation tactics on other individuals and target our human weaknesses and vulnerabilities. What is so dangerous about social engineering? It can happen without the individual knowing about it, or the individual could know, but is being tricked. It could be as little as letting someone through the locked front door at the workplace or apartment. The attacker can come running after an unsuspecting victim when they are walking in and saying, "I forgot my keys, mind letting me in?". If this is a shared entrance or the company has no ID, this would probably end in the victim letting them in and thinking nothing of it. Little do they know; they have just let an attacker in the front door. You may have gotten a few emails throughout the years, but how can you truly know who is the sender? This is a huge problem in the digital era we live in and is a huge challenge. As you probably understand these manipulation attacks can be both in the real world and online.

Right now, you might think "That sounds dangerous and all, but what kind of information could the attacker gain access to this way?". They can gain access to a bunch of valuable information like banking data, logins for websites, encrypted data on hard drives, keycards, private customer information and more. It is also important to know of social engineering when it comes to the

digital world. A well-known and expensive social engineering attack is the CEO fraud technique (EUROPOL, *CEO/business email compromise (BEC) fraud*).

The CEO Fraud (EUROPOL, *CEO/business email compromise (BEC) fraud*) involves trying to trick someone in a company with access to the bank systems to send money out of the company. This could be the CEO sending out an email, a text or a phone call with a fake, but real sounding voice. The receiver thinks it is the CEO and follows the instructions given to them. This is an attack where the victim is manipulated into going along with the attack without even knowing that they have been tricked. The damage of an insider attack depends on what kind of security and cyber security measures are currently being used at the victim's workplace. Is there a security system in place? Are there guards patrolling the area? Is information stored openly without the need for any access codes to get access to them? Are keycards with pictures being used? Do multiple people need to sign off on money transfers? Is a spam filter installed? You might think "Whew, this is a lot" and yes, it is but it is also extremely important for the safety of the workplace.

JSL

Now that I have gone through the basics of social engineering, you may have gotten a decent understanding of how vast and wide it can be, and some of the consequences that can occur. In the following topics, I will go more in depth on the history, techniques and the motivations behind social engineering attacks.

History

The term social engineering was first used by Dutch industrialist JC Van Marken in 1894 (Proofpoint, *What is social engineering?*). In the 1990's hacker Kevin Mitnick brought the word back and has been actively used in cybersecurity since (Cihodariu & Din, 2019).

In the 1990's (Proofpoint, *What is social engineering?*), it started out as a phone call scam where attackers called individuals and tricked the victims into giving the attackers private information which could be abused. Nowadays, attackers often do the same, they trick individuals into giving out similar private information and then the attackers abuse it. The elderly and the unknowing are often victims in these attacks and are sadly tricked into "giving" away all the money in their bank account. The attackers often disguise themselves as bank employees or as higher authorities such as the police or sometimes even as serious as Europol[1] (Politiet, *Svindelforsøk*). Who would not want to cooperate with the bank, the police or Europol?

JSL

At the WHO conference about HIV in 1989 (Arntz, 2023) a biology researcher was handing out floppy disks and emails that contained information about AIDS. The computers that had read the floppy disk or opened the email acted normal for 90 reboots and after that it encrypted itself and demanded a 189$ ransom to be sent to Panama. This is considered the first ransomware attack. The biology researcher abused the fact that it was a HIV conference and probably thought no one would bat an eye at the AIDS information being shared. The researcher used social engineering to trick victims to unknowingly infect themselves and others by hiding the ransomware as AIDS information (Arntz, 2023).

In 1979, the previously mentioned hacker Kevin Mitnick (Mitnick et al., 2002) was dared by another hacker group to gain access to Digital Equipment Corporations (DEC) The Ark. The Ark was used to develop operating system software and had a dial up number you needed to call to gain access to it. The hackers knew of the dial-up number but could not get access to the

[1] European Union Agency for Law Enforcement Cooperation

computer without a username and password. Kevin Mitnick called a system manager working for DEC where he impersonated Anton Chernoff[2] and said he could not access his account. Mitnick manipulated the system manager into giving out the username and changing the password to anything Mitnick chose. This led to Mitnick getting access to not only The Ark but also an account with more access to the systems than a normal user (privileged user). This was a big security risk for DEC but majorly backfired on Mitnick when the hackers turned Mitnick into the Security department in DEC (Mitnick et al., 2002).

JSL

[2] Project Lead Developer on The Ark.

Most common social engineering attacks and techniques

As previously mentioned, social engineering is manipulation of humans, but it is not that simple. There are multiple ways attackers can exploit victims and there are multiple horror stories of it. According to CrowdStrike (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023), attackers often use one or multiple of these ten attack vectors and techniques:

1. ### Phishing

   Attackers operates on a communications platform to share links to get the victim to share personal information. According to FBI (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023), this was the most used form of cyberattack in 2020.

   The victim receives a text message stating that they have a package waiting to be delivered. They click the link, and the website asks for deliver address, email and as a safety precaution they also ask for date of birth. The attacker will state that this is a precaution to make sure that the package gets delivered to the correct address and to verify who the victim is. The victim is told to create a user, and to put in a password and answer some security questions. The victim answer everything and click “finished”. The next day you hear nothing of a package arriving and a week goes by where you forget the whole interaction (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023).

   The victim has freely given the attacker their address, email, date of birth, a possibly re-used password and answers to possibly re-used security questions. This attack target millions of victims.

2. ### Whaling

   This is an advanced form of Phishing, just more personalized. The attacker does the same as in a phishing attack but with personal information and a specific target in mind.

The victim receive an email from one of their new business associates they just added on LinkedIn. The business associate mention products the victim can sell through their company. The victim post on LinkedIn that they are looking for more products in a specific category which the business associate can provide. They send you some product brochures in word and product technical specifications in excel. The victim is informed that the word and excel sheet will not work unless you enable macros, which the victim happily obliges to. The business associate might not be able to provide them with everything, but they continue the talk for a week until they go completely quiet and stop responding (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023).

The victim has just enabled macros on a word and excel document which can let malware run on their computer system and possibly spread. The victim may have sent these documents to colleagues, and they have also enabled macros.
This attack is often time consuming for the attacker and is specially aimed at one person per attack.

JSL

3. ## Baiting

Victim is tricked into giving away personal information or downloading malware from an online advertisement or online giveaways (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023).

The victim sees an advertisement online for a pc giveaway from Komplett.no but the URL seems a little off. “http://komplett-giveaway.biz. The victim clicks on it, and it asks for name, date of birth, address and phone number so the victim can enter the giveaway. The victim wants the free computer, so they enter all their personal information.

The victim clicked on an advertisement that abused a legitimate business and gave away their name, date of birth, address and phone number to an attacker.
This attack is often not time consuming and aimed at millions of users.

4. ## Diversion Theft

Victim is tricked into sending information and/or files to a wrong individual. Attackers often abuse security holes and spoofs email addresses and/or numbers to trick the victim. Spoofing is disguising yourself as something you are not (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023). For example, making it look like a text message or call is coming from phone number "90XX00XX" when it really comes from a totally different phone number. Email addresses are also abused this way.

The victim works as a Lead-Manager and get a text message from their boss and recognizes their phone number as theirs. "Hi, for some reason I cannot access the 5-year expansion plan for your area. I would appreciate if you could send me your latest copy of it to my private email. Bossman@bossemaildomain.com, I stopped using my old one". The victim does what the boss instructs them to do and send the latest copy they have to the email address they were given.

ISL

The victim unknowingly sent away confidential data to the attacker. The phone number was spoofed by the attacker to match the phone number of the boss.

5. ## Business Email Compromise (BEC)

Victim is tricked into going forward with an action which is often based on communication received from a high standing executive. This is often aimed at financial managers and a high standing executive is often abused by the attacker. Spoofing is commonly used to make it seem like the executive sent an email/phone message etc. with instructions. This could lead to major financial loss and possible bankruptcy. Often specified at one person and is hard to detect before it happens since it often comes from legitimate looking URL's or phone numbers (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023).

The financial lead-manager suddenly gets an urgent text from the Chief Executive Officer. "Can you pay our supplier? We just put in a huge order with them and need to

pay it right now. BIC – DNBANOKKXXX AC - NO49 7001 XXXX XXX (DNB IBAN number). I'm in a meeting, do not call me, just transfer the money". The manager suddenly gets a call from the Chief Executive Officer asking about a big transfer they just got alerted of (DNB, *Generate your Iban*).

The financial lead-manager got tricked by the attacker to send money from the company bank account to a bank account in a different country. The text message came from the correct phone number and expressed urgency, which made it seem real. The money is now lost, and the company takes a big financial loss.

6. ## Smishing/SMS-phishing

Victim receives a text message with a message and a URL the attacker wants the victim to interact with. We are often less security oriented over text messages compared to email, so the attacker abuses its place in society. This attack is often sent to many victims from a spoofed number and is easy to do (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023).

The victim receive a text message. "We have tried to deliver your package but could not find your entrance. Please fill out the form below and we will get in touch with you to deliver your package when you are home. https://packagedelivered.ifedex.com"

The victim could have given away private information or downloaded malicious malware from the attacker's link. The text message could show up as being sent from "FedEx".

7. ## Quid Pro Quo

Attacker tries to trick the victim into giving away login credentials or sensitive information by assisting the victim with a task. Attacker could be posing as a technical support or customer service from a well-known company. The attacker could insist that there is an issue with a computer or network and requires the login credentials to the respective system. The famous calls from attackers posing as Microsoft Technical Support falls under this category (Lenaerts-Bergmans, *10 Types of Social Engineering*

Attacks and how to prevent them 2023).

The victim receive a call from Microsoft technical support telling you there is an issue with their business account, and they will help you resolve said issue. The technical support tells the victim that they need access to the victim's system to do it, just a username/email, password and a one-time code the victim receives on email. The victim wants to have their account fixed so they give the "technical support" everything they require.

The victim just gave away the login credentials to their business account which the attacker now can abuse. Victims often re-use the same password on multiple sites. This will give the attackers an opportunity to try the same email and password combination on multiple sites.

8. ## Pretexting

Attacker tries to control the narrative and trick the victim into giving up sensitive information. Attacker often impersonates individuals in government agencies, recruiters or other trades that could get the victim interested in talking to the attacker. Attacker then tries to make the victim share sensitive information (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023).

The victim gets a message from a recruiter; they are eager and wants to interview the victim for a job but need them to fill out a form containing personal and business questions. Of course, the victim wants the job, and therefore fill it out.

The victim has just given away private information and possibly business information that is not public or common knowledge.

9. ## Honeytrap

This attack is aimed at individuals on dating and/or social media sites. Attacker impersonates another individual or has created a fictional account that seems real. The

attacker tries to create a relationship to the victim and abuses that relationship to gather personal or business-related information (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023).

The victim gets a friend request from a name they don't recognize but think nothing of it and accept it. The "friend" sends a message that gets the victims attention. They saw the victims dating profile account and want to get to know them. How swell! After a couple days they start asking about the victim's job, what they do and information on current project. The victim is very interested in the "friend" and reply honestly.

The victim just gave away personal and quite possibly confidential business/project information. The attacker can sell this information and abuse it in a malicious attack on the business or on the victim themself.

10. **Tailgating/Piggybacking**

This is a physical attack and is done in person by the attacker. The attacker tries to gain unauthorized access to a building or area by trying to get the victim to let them in. They could get the victim to hold open the door for them or impersonate someone who often needs access to buildings without having pre-authorized access. This is often the reason for workplaces having safety carousel doors or single person connection portal with access control systems (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023).

The victim unlocks the electronic door at the workplace and walk through the door. A delivery driver yells out and asks for the victim to hold the door open. They let the driver in since someone probably wants their package delivered. The delivery driver thanks you and heads towards the stairs, disappearing.

The victim just let an unknown individual into the workplace, not thinking about the safety risk. The attacker gained unauthorized entry and could possibly roam the area freely.

Attacks

Attacks and platforms

Social engineering attacks can happen to everyone and there is no ultimate platform that can be used to avoid it all. It does not matter if your business is on social media, marketplaces, dating sites, your own webstore or just sell items in bulk to partners over emails and meetings. There are multiple big companies that have been hit and will be hit by successful and unsuccessful social engineering attacks, both present and in the future. With the rise of Work-From-Home, it is more important than ever to make sure your employees have been trained to withstand and detect social engineering attacks. A Lookout report (Security Magazine, 2023) tells us that 13% of individuals working from home has interacted with phishing attacks and fallen for them. To make it even worse, 21% says they will continue working like normal without alerting the proper channels if they fall for phishing attacks. This makes your business vulnerable on its own. The report also tells us that 68% of responders are more likely to use personal devices instead of work-controlled devices. This combo is a huge security risk to your company and could very easily lead to successful attacks on your company. Personal devices are a bigger security threat since the company cannot control what kind of antivirus/antimalware solutions are in place (Security Magazine, 2023).

JSL

Listed below are five different companies that have been hit by successful social engineering attacks that could potentially lead to huge consequences:

From 2013 until 2015 a Lithuanian citizen named Evaldas Rimasauskas committed fraud against Google and Facebook, the fraudulent charges totaled over a hundred million USD. Evaldas impersonated a company that genuinely worked with Google and Facebook. He created real bank accounts for his fake company, invoiced them for goods and services sold and tricked targeted employees to pay the invoices. The invoices looked like they came from the real company, but they were fake and instead transferred money to the fake company. (United States Attorney's Office, 2019)

An Austrian company named FACC was hit by CEO fraud in 2016 which cost them fifty million euros (Cluley, 2016). The CEO at the time, Walter Stephan, sent an email to an employee asking for transfer of funds to cover an acquisition the company was in the middle of. The employee successfully transferred the money, but it turned out to be a CEO fraud. The email was not sent by the CEO and the acquisition was not real either. FACC decided to fire both their CEO and CFO after the attack because they allegedly had not done enough to protect the company from these types of attacks. FACC even took the CEO and CFO to court and demanded eleven million euros from them. The CEO and CFO was released by the court and found not guilty. This attack cost the company millions and the CEO and CFO lost their jobs and ended up in court (Reuters, 2018) (Cluley, 2016).

In 2021, a Microsoft phishing attack was uncovered by security researchers (Tessian, 2023). The attackers were getting the victims to willingly give up username and password combinations for Microsoft accounts. The victims received an email with a price revision.xlsx attachment from a real looking Microsoft email account. When opening the excel attachment, the victims were redirected to a website where a popup told them they had been logged out of their Microsoft accounts. The victim could then enter their username and password on that site. The email attachments were a HTML file that redirected the browser to the attackers Microsoft lookalike website with a popup prompting for user username and password. If the user entered and sent the information requested, the attackers had access to the victims Microsoft account and could easily abuse it. (Tessian, 2023)

In 2021, Lockbit ransomware attacked Merseyrail, a UK rail network company, and abused the company's email in a social engineering attack (Abrams, 2021). The attackers breached Merseyrail's network and used ransomware to take over and encrypt their computer system. Ransomware groups often extract information and then blackmail the victim for even more money. In this case, Lockbit group went even further. The attackers used information they gained from the initial attack on Merseyrail's system and breached Andy Heath's, Merseyrail CEO, email account. They then proceeded to send an email to multiple journalists and staff while disguising themselves as Heath. The email contained information about the attack and previous

attacks. According to Bleeping computer, the heading read as follows “Lockbit Ransomware Attack and Data Theft”. The attackers wrote that an earlier attack was downplayed, and that customer and employee data was stolen. The company was hit by a ransomware attack which possibly forced them to take their whole system offline for multiple days and completely took control over a credible email account (Abrams, 2021) (Tessian, 2023).

In 2023, Linus Media Group’s YouTube channels “Linus Tech Tips”, “TechLinked” and “Techquickie” had all their videos deleted (Peters, 2023). On each channel the attackers live streamed Elon Musk talking about cryptocurrency. The live stream was not really Elon Musk, but a fake video promoting a cryptocurrency scam. The attack they were hit by circumvented the need for a username, password and multi factor authentication. The attackers gained access by tricking an employee to download and open a PDF from a potential sponsor. The PDF was not from a real sponsor. This shows how dangerous opening email attachment is, even for relatively small businesses (Peters, 2023) (Youtube, 2023).

JSL

Motivation

A social engineering attack is one part of a cyber-attack and is oftentimes the starting point of something bigger. In IBM’s article “What is a cyberattack” they state that “a cyberattack is any intentional effort to steal, expose, alter, disable, or destroy data, applications or other assets through unauthorized access to a network, computer system or digital device (IBM, *What is a cyberattack?*)”. This is very much correct, but there is more behind the motivation of the attacker. Nowadays, all you need to launch a cyberattack is a computer and an internet connection. Since “everyone” can launch some sort of cyber-attack from their bedroom, it is hard to know for sure what their intentions are but according to IBM (*What is a cyberattack?*), it is usually one of three categories:

1. Criminal

   The attacker tries to gather information they can sell on dark web marketplaces, commit CEO fraud against an organization or gain access to a network that they can abuse. Nowadays, attackers often hold systems for ransom by using ransomware to encrypt data

or DDOS attacks to halt server processing. This category is usually financially motivated. Example: A single business email attack against CNA Financial had a total ransom cost of 40 million USD. CAN Financial paid the ransom (Chang, 2021).

2. Political

   The attacker has a political gain and abuses computer systems to disrupt the other party's infrastructure and internet connected systems. This could include bringing down servers, taking out important infrastructure and/or gain access to sensitive government information which could be abused by another government. There are known government backed groups actively abusing cyberattacks: APT28 – Linked to Russia, APT3 – Linked to China, Lazarus Group – Linked to North Korea (MITRE ATT&CK, *Groups*).
   Often linked to war between counties (cyberwarfare), terrorism (cyberterrorism) or political organizations with different views (hacktivism). Example: Ukraine's internet/mobile provider Kyivstar was hit by a cyberattack in 2023 that completely halted customers access to the internet and stopped air raid alerts. The attacker is unknown but considering the ongoing war between Russia and Ukraine it believe to be done by Russian supporters or government bodies (Toulas, 2023).

3. Personal

   This attack is often done by former employees, competitors or disgruntled individuals. The motivation behind these attacks is often workplace related. A well-known example of this is when Joshua Schulte, a disgruntled former employee at CIA, leaked sensitive data to WikiLeaks multiple times from 2015-2022. Schulte was mad at the CIA management which lead to him leaking a lot of sensitive data. (Frehse & Morales, 2024)

(IBM, *What is a cyberattack?*) (*Understanding Targeted Attacks: Goals and Motives* 2015)

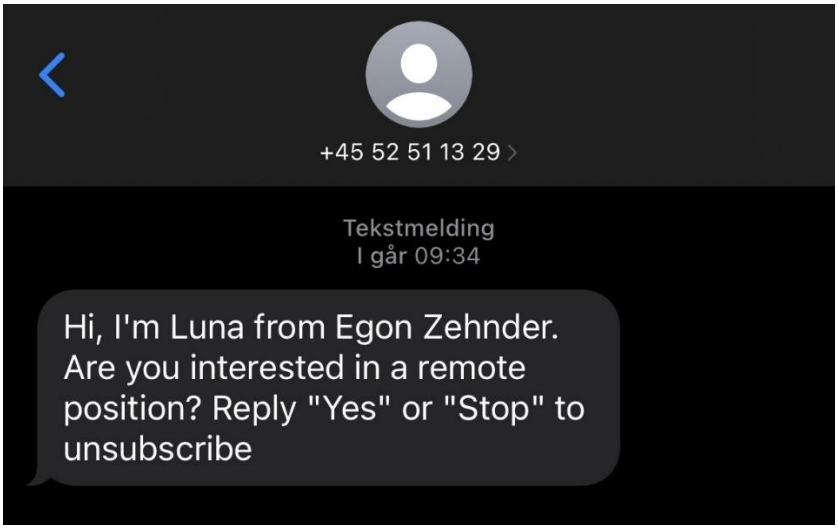
Only the person committing the social engineering based cyberattack truly knows why they did it and what drove them to it. That is because we are humans, and our true feelings are hard to figure out for others but ourselves.

Personal vs business

Personal

No-one likes getting spam calls, text messages and emails. We all find it extremely annoying and all of us receive it from time to time. However, social engineering attacks aimed at victims at a personal level are quite often very bad and easy to spot. I will show you two phishing text messages I have received, explain what the attackers want me to do and how I spot that this is a phishing message.

Picture 1 - Showing a text message that I got from +45 52 51 13 29 that is trying to get me to reply to a phishing message in English.



The attacker in this case tries to get me interested by tempting me with a remote job position and wants me to interact with the message. If I interact with this message, I will likely be a target for more phishing messages since I have showed the attacker that I interact with messages I get from unknown numbers. What tells me that this is a phishing message is the use of an unknown number and country code. I live in Norway which uses +47. Neither have I applied to any job applications in Denmark and no serious job offer would end with “Reply ‘Yes’ or ‘Stop’ to unsubscribe”. Why would I want to unsubscribe from a job offer? It is also worth thinking about what language they use in the message. In this case the attacker used English when they just as easy could have used Danish. This is one of the easier scams to spot.

Picture 2 – Showing a text message that I got from yinmeixun27020@icloud.com containing a fake post office message in Norwegian.

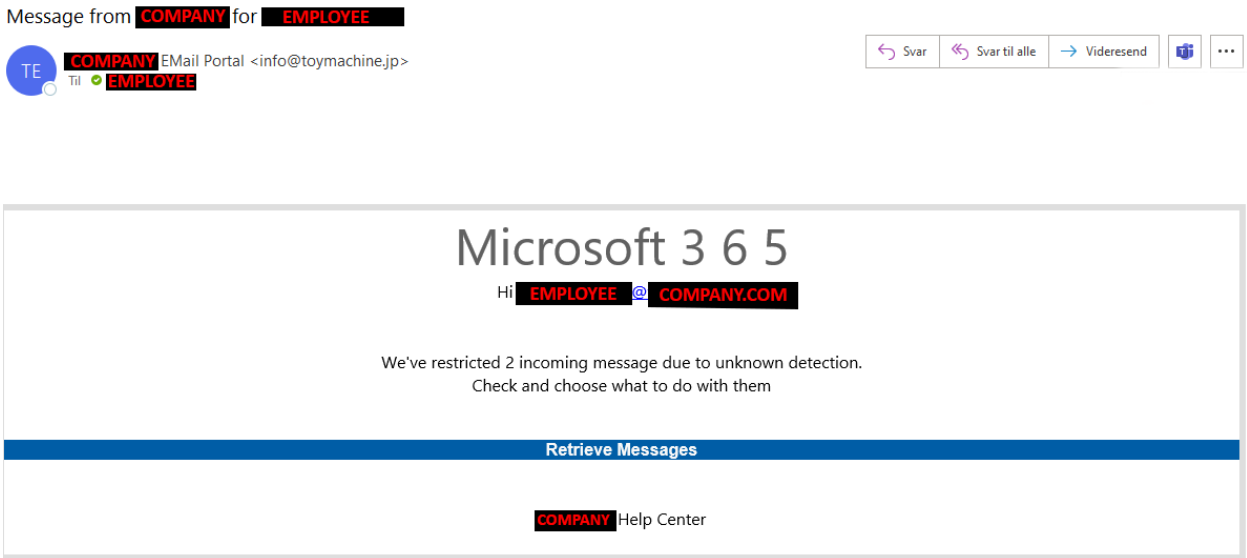
The issue I had with language in the first message is resolved in this one. It is aimed at a Norwegian person and is in Norwegian. This is message has some work put in it and could be seen as more "reliable" since it is in the victim's language. The attacker tries to get me to click the link and probably fill out personal information they can abuse or sell online by posing as a shipping company. In Norway we have multiple shipping companies; Posten, DHL, FedEx, TNT and PostNord etc. It is unclear if they are trying to pose as one of these companies, but the attackers are trying to get goodwill from the victim by abusing the shipping name. One issue that is seen immediately is the sender, "yinmeixun27020@icloud.com". It is not a real phone number, and the email does not look like a shipping email. From a technical standpoint, there are multiple issues with this message. It is from a clearly suspicious email; the email domain is Apple's @icloud, and URL is not linked to a Norwegian ".no" domain or any other common domains. The URL leads to a 404 Not Found, which could mean the website has been taken down by the hosting company. According to VirusTotal[3], 4 out of 91 antivirus scanners marks it as phishing, malicious or spam (*Virustotal*).

[3] Website that collects Antivirus scanners. Can scan URL's and documents.

Business

No-one likes getting spam and phishing messages on a personal level, but it is even more annoying getting them at your workplace. Phishing and general social engineering attacks aimed at a business is often more personalized and specifically made for one person instead of hundreds of thousands. The attacker is trying to gain sensitive information or siphon a considerable amount of funds out of the company. Below I will show multiple images from businesses that got phishing email, some of them are easy to spot and others could just as well be real. Sometimes it is hard to spot a phishing email vs a real email. In the pictures I have replaced the company name with “COMPANY” and the employee with “EMPLOYEE” or “EMP” for privacy purposes.

Picture 1 - Showing a real phishing email that a business got which contains a phishing attack.



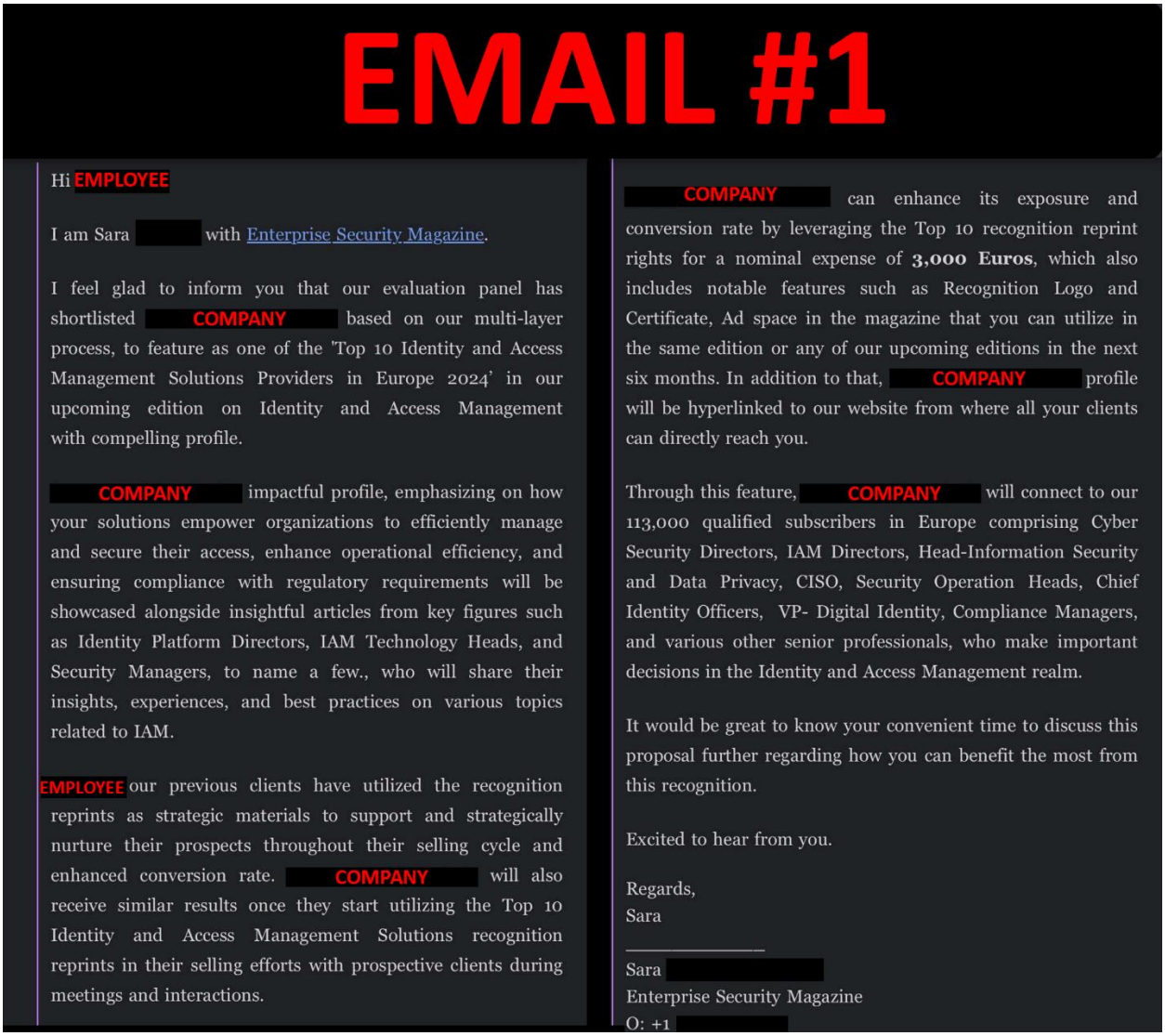
In this email the attackers try to trick the victim into believing they received email is from the outlook email system. Let us pretend the company is Apple and the Employee is Steve. The email seems like it is from Apple to Steve and tells us that there are two restricted messages which have been stopped by the Microsoft 365 system. The attackers have also hidden a link in “Retrieve message” which redirects to a Microsoft lookalike that asks you to log in. Something that is also off is “Microsoft 3 6 5”, Microsoft probably would have written this as “Microsoft 365”. The only difference is the space between the numbers. All in all, the email seems legit, or

does it? A major issue with this email which tipped of the original recipient was the actual email it was sent from. It looks like it is from Apple email portal, but it also shows the email as “info@toymachine.jp”. Since the email is supposedly from Apple, why is the email domain so wrong?

This is a well-made email which only had some small issues that immediately told us it was a fake email - the email domain and the spacing between the numbers in Microsoft 3 6 5 logo. The attached link would probably also have made it clear that this is fake. The aim of this phishing email is to gather log-in data from the original recipient, a Chief Financial Officer, and abuse it. This attack could lead to a Business Email Compromise by abusing the breached email and then start a CEO (CFO) fraud by instructing someone to transfer funds out of the company.

JSL

Picture 2 – Email where it is uncertain if it is a phishing attempt or not, consists of two pictures.



EMAIL #1

Hi EMPLOYEE

I am Sara [redacted] with Enterprise Security Magazine.

I feel glad to inform you that our evaluation panel has shortlisted [redacted] COMPANY based on our multi-layer process, to feature as one of the 'Top 10 Identity and Access Management Solutions Providers in Europe 2024' in our upcoming edition on Identity and Access Management with compelling profile.

[redacted] COMPANY impactful profile, emphasizing on how your solutions empower organizations to efficiently manage and secure their access, enhance operational efficiency, and ensuring compliance with regulatory requirements will be showcased alongside insightful articles from key figures such as Identity Platform Directors, IAM Technology Heads, and Security Managers, to name a few., who will share their insights, experiences, and best practices on various topics related to IAM.

EMPLOYEE our previous clients have utilized the recognition reprints as strategic materials to support and strategically nurture their prospects throughout their selling cycle and enhanced conversion rate. [redacted] COMPANY will also receive similar results once they start utilizing the Top 10 Identity and Access Management Solutions recognition reprints in their selling efforts with prospective clients during meetings and interactions.

[redacted] COMPANY can enhance its exposure and conversion rate by leveraging the Top 10 recognition reprint rights for a nominal expense of **3,000 Euros**, which also includes notable features such as Recognition Logo and Certificate, Ad space in the magazine that you can utilize in the same edition or any of our upcoming editions in the next six months. In addition to that, [redacted] COMPANY profile will be hyperlinked to our website from where all your clients can directly reach you.

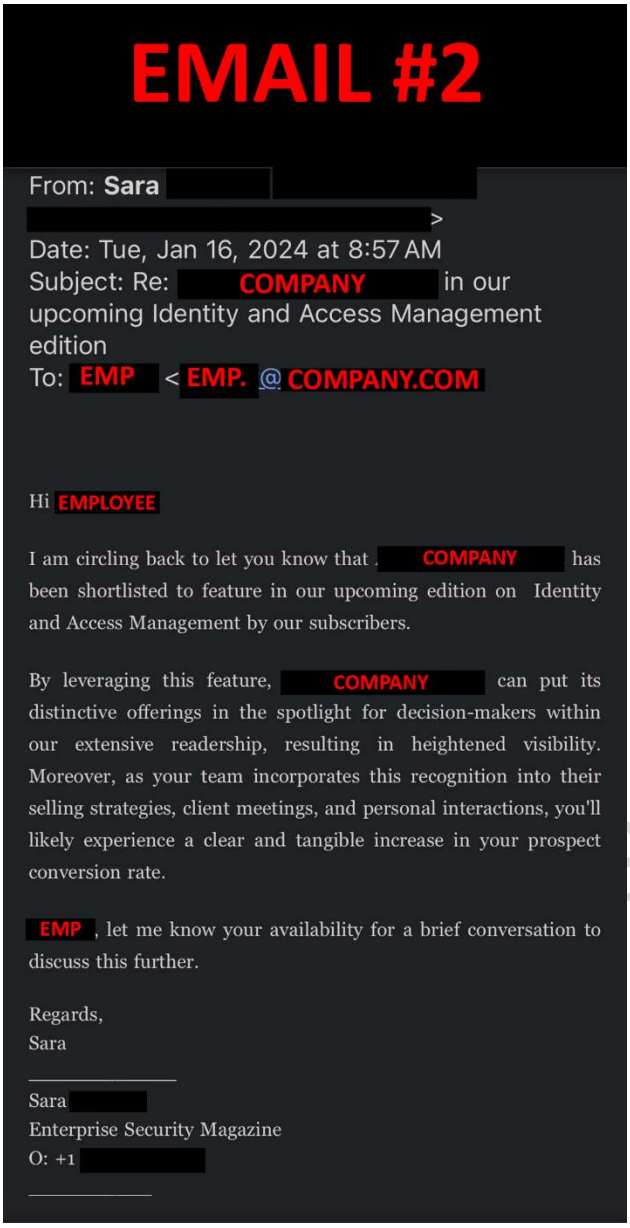
Through this feature, [redacted] COMPANY will connect to our 113,000 qualified subscribers in Europe comprising Cyber Security Directors, IAM Directors, Head-Information Security and Data Privacy, CISO, Security Operation Heads, Chief Identity Officers, VP- Digital Identity, Compliance Managers, and various other senior professionals, who make important decisions in the Identity and Access Management realm.

It would be great to know your convenient time to discuss this proposal further regarding how you can benefit the most from this recognition.

Excited to hear from you.

Regards,
Sara

Sara [redacted]
Enterprise Security Magazine
O: +1 [redacted]



EMAIL #2

From: Sara [redacted]
[redacted] >
Date: Tue, Jan 16, 2024 at 8:57 AM
Subject: Re: COMPANY in our upcoming Identity and Access Management edition
To: EMP < EMP. @ COMPANY.COM

Hi EMPLOYEE

I am circling back to let you know that . COMPANY has been shortlisted to feature in our upcoming edition on Identity and Access Management by our subscribers.

By leveraging this feature, COMPANY can put its distinctive offerings in the spotlight for decision-makers within our extensive readership, resulting in heightened visibility. Moreover, as your team incorporates this recognition into their selling strategies, client meetings, and personal interactions, you'll likely experience a clear and tangible increase in your prospect conversion rate.

EMP , let me know your availability for a brief conversation to discuss this further.

Regards,
Sara

Sara [redacted]
Enterprise Security Magazine
O: +1 [redacted]

In these emails, the sender looks real, and the company is a real company. Nothing about this email or sender seems fishy at a first glance but with some background information it seems a tiny bit off. More on that later, let us go over the emails: The emails are from Sara at Enterprise Security Magazine (ESM) and "user@emaildomain" looks like a real domain. Sara wants to sell the company an ad-spot containing everything about the company in their magazine. Sara keeps repeating sales tactics to really make the ad space worth it, but for only "3,000 Euros". In the second email, Sara tries to sell the ad space again and really drive the worth home. It is a really good product!

What is suspicious about these two emails you might think? Multiple points made me and the original recipient suspicious. The first point of suspicion is that the magazine is not well-known. Search engine searches leads to their website, but the second recommended search is "Enterprise Security Magazine Spam", which is suspicious. The recipient company is a fresh start up in Norway but is very big in a neighboring country, why would they need the ad space? The third suspicious point worth mentioning is how hard Sara tries to sell the ad, that makes it look like an annoying spam email.

However, I cannot tell with a 100% certainty that this is a phishing email. This is the reality of doing business and shows how hard it is spotting social engineering attacks if they are properly created and aimed at a single individual or business. There are certain ways to make sure that an

email is trustworthy except talking face to face with the person who sent it and asking them if they sent it. Of course, this is hard and, in some cases, impossible but everyone must make up their own opinion based on multiple factors.

JSL

Practical demonstration

Social engineering attacks are easy to launch. All you need is a computer that runs Linux Kali. Kali is a Linux distribution that is aimed towards penetration testers and is often used by security professionals and cybercriminals. It is a collection of tools that are just a command line away. If you ever talk with a penetration tester, ask them if they have ever used Kali, all of them will say yes. They might even use it daily in attacks both remote and physical (*Kali Linux Features*).

The examples below are meant to be informational and should not be abused for malicious actions. I will use non-malicious sites to show how easy it is to trick victims. These attacks could just as easy be used for malicious attacks. The attackers and victims' side will appear after each other.

JSL

QR Code phishing attack

For this attack you need Kali Linux and a victim. In this case, the victim is an Apple smartphone. The attacker creates a QR Code that opens a Grabify link which can collect the users IP, Country, browser and device information. After the Grabify service has collected information, the victim is redirected to an attacker's chosen website. Grabify is a free website but with premium you can unlock more information about the victim and custom domains, so the Grabify part of the link is hidden.

Attacker example:

1. Open Kali Linux, log in to the system and open the command-line.
2. Type in "sudo setoolkit"

```
┌──(root㉿kali)-[~]
└─# sudo setoolkit
```

3. You are now prompted with a lot of social engineering attacks, choose "1. Social-Engineering Attacks"

```
1) Social-Engineering Attacks
```

4. Select “8. QRCode Generator Attack Vector”

```
8) QRCode Generator Attack Vector
```

5. Your QR Code is ready to be created, input the target website. In this case, the target website is a grabify link redirecting the user to https://vg.no which is a real, non-malicious new site.

```
The QRCode Attack Vector will create a QRCode for you with whatever URL you want.

When you have the QRCode Generated, select an additional attack vector within SET and
deploy the QRCode to your victim. For example, generate a QRCode of the SET Java Appl
et
and send the QRCode via a mailer.

Enter the URL you want the QRCode to go to (99 to exit): https://grabify.org/2EqF
```

6. Your QR Code will now be created, and the file location will be shown in the command-line

```
[*] QRCode has been generated under /root/.set/reports/qrcode_attack.png
```

7. The QR Code is now ready to be given to the user. This can be done by mass email attacks or printing it out and sticking it to walls where the victim is located, like the subway or around the area of a targeted victim. In this case I scanned the URL with my phone and Grabify collected my information and redirected me to a new site.
8. Enter Grabify and see what information has been collected

Date/Time	IP/Provider	Country	Device	Referer	More
1/31/24 7:52:51 PM	178.231[redacted] Get AS	Norway Oslo	iOS 17.0 Safari 17.0	no referer	More
Mozilla/5.0 (iPhone; CPU iPhone OS 17_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.0 Mobile/15E148 Safari/604.1					
1/31/24 7:52:21 PM	178.231[redacted] Get AS	Norway Oslo	iOS 17.0 Safari 17.0	no referer	More
Mozilla/5.0 (iPhone; CPU iPhone OS 17_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.0 Mobile/15E148 Safari/604.1					
1/31/24 7:14:58 PM	178.232[redacted] Get AS	Norway Oslo	iOS 17.0 Safari 17.0	no referer	More
Mozilla/5.0 (iPhone; CPU iPhone OS 17_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.0 Mobile/15E148 Safari/604.1					

date	1/31/24, 7:52:51 PM
ip	178.232[redacted]
browser	Safari 17.0
platform	iOS 17.0
isp	Get AS
useragent	Mozilla/5.0 (iPhone; CPU iPhone OS 17_0_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.0 Mobile/15E148 Safari/604.1
country	Norway
city	Oslo
state	Oslo
referer	no referer
bot	No
latitude	59.94330000000000000
longitude	10.86850000000000100
accuracy	ip

As you can see in the pictures above, a lot of information has been collected. This information is not extremely sensitive, but the Grabify link could just as easy has been a download site for malware that automatically downloaded.

Victim example:

1. Victim sees a QR Code on the subway or in an ad that makes the victim curious.

2. Victim scans QR Code with their phone and opens it in their browser.

3. Victim is opening a Grabify link, but it almost instantly redirects the victim to a real news site.

4. Victim can see the grabify URL in the top bar of their browser for 45 milliseconds. The victim would easily miss this by blinking, looking at another part of their phone or not knowing what grabify is.

Credential Harvesting

For a credential harvesting attack, you also need Kali Linux and a victim. The target could be a smartphone or a computer, it does not matter. In this attack, an email is sent to the victim which needs to interact with a link. It works by copying a real website and presenting it to the victim which is tricked into giving out login information. Login information is usernames, emails and passwords. The dangerous part about this attack is that victims often re-use passwords on multiple websites. One breach could lead the attacker to gain access to multiple accounts over multiple websites. The example below is not made to trick anyone but to show how easy it is to be the attacker and the victim.

Attacker example:

1. Open Kali Linux, log in to the system and open the command-line.
2. Type in "sudo setoolkit"

```
┌──(root㉿kali)-[~]
└─# sudo setoolkit
```

3. You are now prompted with a lot of social engineering attacks, choose "1. Social-Engineering Attacks"

```
1) Social-Engineering Attacks
```

4. Select "2. Website Attack Vectors"
5. Select "3. Credential Harvester Attack Method"
6. Choose "Web Templates" or "Site Cloner". I choose "Site Cloner."
7. Input the fake website IP. This would normally be your external IP.
8. You will now have to change configurations for the attack module, I am not showing you how to do this, but you can change what website the victim will be redirected to after inputting their credentials.
9. Here you choose your website template, I choose Google.
10. Now you wait for the victim to input credentials on the malicious site. It would help to spread the link in a phishing email or text message, example:
    "Something is wrong with your Google account. Please click the link and log in to make sure you don't lose access to your account. https://google.com/login".
    In this message the user is told something is wrong with their Google account and it

contains a link which shows up as google.com. The link leads to a shortened URL that sends the user to the attacker's malicious website.

11. We tricked someone! They even left their email and password, let us see what it is

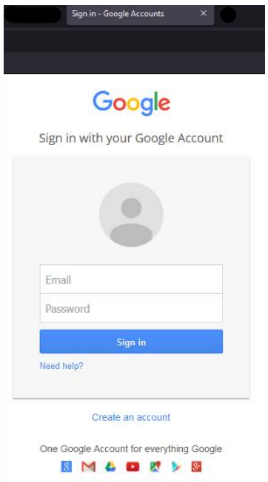
```
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168[redacted] - [03/Feb/2024 12:57:02] "GET / HTTP/1.1" 200 -
192.168[redacted] - [03/Feb/2024 12:57:02] "GET /favicon.ico HTTP/1.1" 404 -
192.168[redacted] - [03/Feb/2024 12:58:18] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLCkfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hI
cDhtUFdldzBENhIfVWsxSTdNLW9MdThibW1TMFQzVUZFc1BBaURuWmlRSQ%E2%88%99APsBz4gAAA
AAUy4_qD7Hbfz38w8kxnaNouLcRiD3YTjX
PARAM: service=lso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=â
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=john@noroff.no
POSSIBLE PASSWORD FIELD FOUND: Passwd=Password123
PARAM: signIn=Sign+in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

We can now use that information and log into their account.

JSL

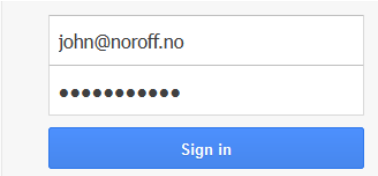
Victim example:

1. Ping! The victim just got an email or a text message that reads:
   "Something is wrong with your Google account. Please click the link and log in to make sure you don't lose access to your account. https://google.com/login".
2. Victim wants access to their account, so they click the google.com link

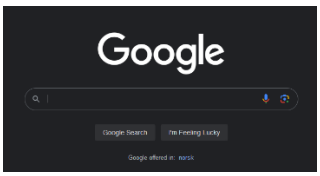


The malicious website looks real, has all the google applications listed and even has "Sign in - Google Accounts" in the top of the website tab.

3. The victim wants access to their account and logs in.



4. User is instantly redirected to the real google.com and probably thinks nothing of it.



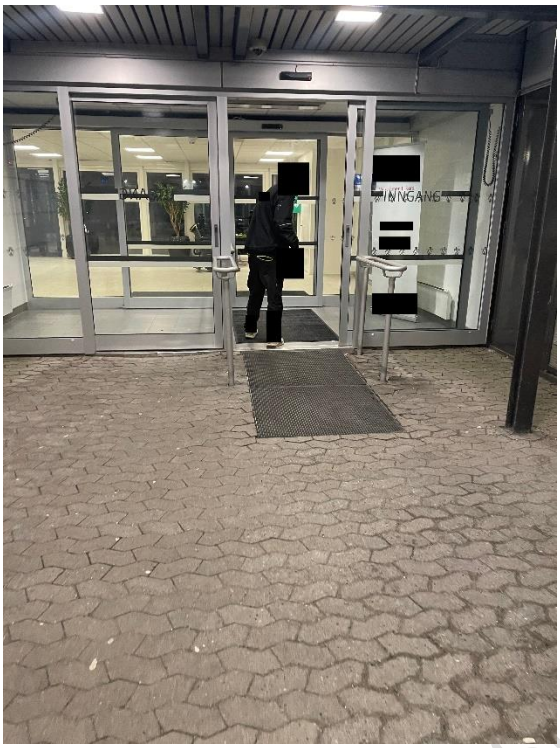
Tailgating (physical)

For this attack you only need yourself, a locked door and a victim. With this attack the attacker can easily gain access to buildings and areas that are protected by keypads or access control systems. This allows the attacker to bring malicious tools, export data and gain long time access to the computer systems in the area. The attack is shown in a picture below, but the building and area is censored for privacy purposes for the victim and simulated attacker. Please note: This was not an illegal attack. I have access to this door but refrained from using it so I could simulate the attack.

Attacker example:

1. Attacker stands close to the area they want to enter.
2. Victim is spotted and attacker yells at the victim to "Please hold the door for me!"

3. Attacker is let into an unauthorized area and can roam around freely if no-one identifies the attacker as unauthorized personnel.



As you see in the picture above, the victim was “kind” enough to help the attacker into a building where attacker has no access to. The door was protected by a card and pin combo that the attacker had no access to.

Victim example:

1. Victim is heading into a building and unlocks the entrance door.
2. Victim hears someone yelling to please hold the door.
3. Victim is kind and wants to help the individual asking for help.
   Unknowingly the victim just let the attacker in.

Prevention

After reading this document you probably think, “How could one possibly defend against social engineering attacks?”. The easy answer, employee training. This is the only way to prevent a lot of these attacks. With the rise of AI and deepfake videos and images, there will be times when we cannot prevent ourselves from being tricked. Sure, the attack might be mitigated and stopped but people will fall for these attacks since they could be targeted and very well made. It is extremely important to protect yourself, as well as your organization. To prevent social engineering attacks, you need to be protected against cyberattacks. Your organization should have an IT team with preventive solutions running. This could be an internal IT team or a managed service provider/managed security service provider. The IT teams has access to multiple prevention solutions which could be used but they all cost money. Some are very expensive, and some are cheaper. You do not necessarily need the best and most expensive software or hardware, but you should have your team gather multiple solutions and present them to you to defend against normal cyberattacks.

ISL

Let us head straight into the most basic things you and your employees should never do.

- You should never give out any passwords, sensitive or confidential information anyone could abuse. This is your information and if anyone needs to know this, they are not who they pretend to be. Example: The police call you and ask for your login information and wants you to provide them access. The police will never contact you regarding this and will contact the company itself for access to your or others information (*Avoiding Social Engineering and Phishing Attacks* 2021).
- If sensitive information is being discussed, do not respond to the communication. You should search for the company or individuals contact information and contact them yourself. This way you make sure the phone call or email etc. you received is genuine and from the actual individual and not any scammer. Example: Your bank calls you and you pick up. They ask for your personal identity number to verify who you are. (“Personnummer” is used in Norway). It is recommended you somehow verify that they are who they are. This can be done by asking who they are, hanging up and looking at their website for contact information. This way you know the call is real and not

malicious (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023), (*Avoiding Social Engineering and Phishing Attacks* 2021).

- Do not click on links in emails and text messages. Those could be altered and malicious. Search for the organizations website and access the page. This way you know the link is real and not altered. Example: You get a text message from "Your bank" where they inform you that "Something is wrong with your account, and you must act immediately. Click here for more information." The "here" part of click here for more information is blue and redirects you to a lookalike site to your bank. Here they could require you to sign in with BankID[4] and steal your information. A solution here is searching for your banks URL on a search engine and avoiding clicking the link in the text message (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023), (*Avoiding Social Engineering and Phishing Attacks* 2021).
- Do not open emails or file attachments sent from anyone you do not trust. As mentioned earlier in Attacks and platforms, the Linus Tech Tips (Peters, 2023) attack only used a pdf file to wreak havoc. Imagine what an innocent looking but malicious word document could do to your company. Always make sure the file is clean. This can be done by asking your IT staff to check the document, scanning it with an antivirus software or checking it with malware detection websites like VirusTotal or Hybrid Analysis (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023), (*Avoiding Social Engineering and Phishing Attacks* 2021).

The above-mentioned solutions is something your employees should constantly keep in mind, personally and professionally. From time to time, you need to train your employees and make sure they are alert and constantly doing the basic prevention activities above. The most common attacks will probably be stopped in its tracks by just being careful and keeping an eye out for suspicious activity. However, sophisticated and targeted attacks will have ways to circumvent a lot of basic prevention practices. Below are some of the most effective solutions to protect against social engineering attacks, and solutions I recommend actively running on your

[4] Electronic way of identifying who you are. Used by banks, healthcare and government organizations etc. in Norway.

organizations system according to CISA (2021) and Kaspersky (*Ways to avoid social engineering attacks*):

- Network firewalls (Next-Generation and traditional)
  These firewalls can stop malicious files, messages and network packets that are sent through the firewall. This solution can also stop employees from accessing malicious links and having harmful files accessible to the user.

- Employee training
  If all else fails, this is the only solution you can fall back on. Your employees should know how to spot social engineering attacks in case every other solution fails, or a targeted attack make its way through security solutions. Some attacks are well made and will inevitably make it through to your employees. I recommend phishing tests and then base employee training around the results from the test. Whatever you do, do not punish your employees for failing these tests. Everyone will fail them sometime, yourself included.

JSL

- Zero-Trust security
  Employee permissions on computer systems are kept to the bare minimum. This limits what your employee can run on their systems and mitigates malware access if they gain access. It also makes sure no-one can access anything they should not have access to (finances, sensitive and confidential information) (Raina, 2023).

- Enforce two- factor authentication (2FA).
  This is an authentication solution which will make employees authenticate in two ways before gaining access to websites or internal login pages. Employees must provide username and passwords before inputting a code produced by an authentication phone app or using usb security keys. This makes sure an employee is who they are and not a malicious actor. (Cloudflare, *What is two-factor authentication? | 2 step verification explained*)

- Active spam filter

  Keep your communication platforms clean by filtering out malicious and suspicious emails. If your employee can not see the phishing or malicious file, they cannot interact with them and fall for it. These filters can be included in email software or by the IT team that can scan every email going in and out. Having everything scanned before it gets sent through the system, is recommended. This allows for blocking of geo-location, suspicious email domains and malicious files.

- IT support emergency contact

  If one of your employees or you fall for any social engineering attacks, and they figure it out after the attack has been successful. Your IT support should be knowledge and have procedures in place that they can activate if someone has fallen for an attack. The faster IT is alerted, the quicker they can activate these procedures which can protect the company and the victim itself. If an emergency contact is established, it is of-course important that IT has easy-access to operating procedures that are verified and available. If no procedure is in place, every IT personnel will do something different and might miss something they should be doing to mitigate the attack.

(CISA, 2021) (Kaspersky, *Ways to avoid social engineering attacks*) (Lenaerts-Bergmans, *10 Types of Social Engineering Attacks and how to prevent them* 2023)

Conclusion

In this report we have explored what social engineering is, social engineering throughout history, common attacks and techniques, how attacks have happened, attackers' motivation, personal attacks and business attacks, how to easily create an attack and exploit your victims and what you should do to prevent an attack on your own organization. To make sure you have covered all you tracks, you should hire a professional and knowledgeable IT team.

To be able to run an organization you need employees, and employees means hiring humans to do different jobs that has activities and information that can damage your company. Since we are reliant on each other and connected to a computer system somehow, there will be cyber- and social engineering attacks aimed at your organization in the future. It is just a matter of time. Nothing is completely safe and malware proof and humans are flawed. It does not matter what procedures or security solutions you have in place, one day someone in your organization will fall victim to a social engineering attack. However, what you can do to combat this is implementing different technical and physical solutions to make sure that you are not an easy target and that the damage is kept to the bare minimum.

This is why humans are the weakest link. We are creatures with feelings, and they can be abused maliciously without us knowing about it. This is why you should hire us to prevent your organization from falling victim to social engineering attacks.

We can help you!

References

Understanding Ransomware Threat Actors: LockBit (2023) *Cybersecurity and Infrastructure Security Agency CISA*. Available at: https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-165a (Accessed: 03 March 2024).

(No date) *Virustotal*. Available at: https://www.virustotal.com/gui/url/2b897d79bc2b4fb7cf19de8170f6ea185da30ff0e82239bdbc497002c73979bc (Accessed: 03 March 2024).

13% of employees admit to falling for phishing attacks working at home (2023) *Security Magazine* . Available at: https://www.securitymagazine.com/articles/99846-13-of-employees-admit-to-falling-for-phishing-attacks-working-at-home (Accessed: 03 March 2024).

15 Examples of Real Social Engineering Attacks (2023) *Tessian*. Available at: https://www.tessian.com/blog/examples-of-social-engineering-attacks/ (Accessed: 03 March 2024).

404 Not Found (no date) *MDN Web Docs*. Available at: https://developer.mozilla.org/en-US/docs/Web/HTTP/Status/404 (Accessed: 03 March 2024).

5 Examples of Top Social Engineering Attacks (2023) *Mitnick Security Consulting*. Available at: https://www.mitnicksecurity.com/blog/top-social-engineering-attacks (Accessed: 03 March 2024).

Abrams, L. (2021) *UK rail network Merseyrail likely hit by Lockbit ransomware*, *BleepingComputer*. Available at: https://www.bleepingcomputer.com/news/security/uk-rail-network-merseyrail-likely-hit-by-lockbit-ransomware/ (Accessed: 03 March 2024).

Arntz, P. (2023) *A history of ransomware: How did it get this far?*, *Malwarebytes Labs*. Available at: https://www.malwarebytes.com/blog/news/2023/09/history-of-ransomware-and-how-did-it-get-this-far (Accessed: 03 March 2024).

Avoiding Social Engineering and Phishing Attacks (2021) *Cybersecurity and Infrastructure Security Agency CISA*. Available at: https://www.cisa.gov/news-events/news/avoiding-social-engineering-and-phishing-attacks (Accessed: 03 March 2024).

CEO/business email compromise (BEC) fraud (no date) *Europol*. Available at: https://www.europol.europa.eu/sites/default/files/documents/4_ceo-bec_fraud.pdf (Accessed: 03 March 2024).

Chang, B. (2021) *One of the biggest US insurance companies reportedly paid hackers $40 million ransom after a cyberattack, Business Insider*. Available at: https://www.businessinsider.com/cna-financial-hackers-40-million-ransom-cyberattack-2021-5?r=US&IR=T (Accessed: 03 March 2024).

Cihodariu , M. (2019) *What is social engineering?, Heimdal Security Blog*. Edited by A. Din. Available at: https://heimdalsecurity.com/blog/what-is-social-engineering/ (Accessed: 03 March 2024).

Cluley, G. (2016) *Aerospace firm loses $47 million in cyber fraud, fires CEO, Bitdefender Blog*. Available at: https://www.bitdefender.com/blog/businessinsights/cyber-fraud-ceo-fired/ (Accessed: 03 March 2024).

Cryptocurrency (no date) *Merriam-Webster*. Available at: https://www.merriam-webster.com/dictionary/cryptocurrency (Accessed: 03 March 2024).

FACC sues former CEO, CFO for $11 million over cyber fraud failings (2018) *Reuters*. Available at: https://www.reuters.com/article/idUSKBN1O91JX/ (Accessed: 03 March 2024).

Frehse, R. and Morales, M. (2024) *Former CIA employee sentenced to 40 years in prison after carrying out largest data leak in agency's history, CNN Politics*. Available at: https://edition.cnn.com/2024/02/01/politics/joshua-schulte-sentence-cia-leak/index.html (Accessed: 03 March 2024).

Generate your Iban (no date) *DNB*. Available at: https://www.dnb.no/en/business/calculators/Iban.html (Accessed: 03 March 2024).

Groups (no date) *MITRE ATT&CK*. Available at: https://attack.mitre.org/groups (Accessed: 03 March 2024).

Kali Linux Features (no date) *Kali*. Available at: https://www.kali.org/features/ (Accessed: 03 March 2024).

Lenaerts-Bergmans, B. (2023a) *10 Types of Social Engineering Attacks and how to prevent them*, *Crowdstrike*. Available at: https://www.crowdstrike.com/cybersecurity-101/types-of-social-engineering-attacks/ (Accessed: 03 March 2024).

Lenaerts-Bergmans, B. (2023b) *What Is Social Engineering?*, *Crowdstrike*. Available at: https://www.crowdstrike.com/cybersecurity-101/social-engineering/ (Accessed: 03 March 2024).

Lithuanian man pleads guilty to wire fraud for theft of over $100 million in fraudulent business email compromise scheme (2019) *Southern District of New York*. Available at: https://www.justice.gov/usao-sdny/pr/lithuanian-man-pleads-guilty-wire-fraud-theft-over-100-million-fraudulent-business (Accessed: 03 March 2024).

Malware (no date) *Computer Securtiy Resource Center CSRC*. Available at: https://csrc.nist.gov/glossary/term/malware (Accessed: 03 March 2024).

MFA (no date) *Computer Security Resource Center CSRC*. Available at: https://csrc.nist.gov/glossary/term/MFA (Accessed: 03 March 2024).

Mitnick, K.D., Simon, W.L. and Wozniak, S. (2002) *The Missing Chapter from The Art of Deception by Kevin Mitnick*, *The Memoryhole*. Available at: https://web.archive.org/web/20090317050834/http:/www.thememoryhole.org/lit/deception-ch1.htm (Accessed: 03 March 2024).

My channel was deleted last night (2023) *YouTube*. Available at: https://www.youtube.com/watch?v=yGXaAWbzl5A (Accessed: 03 March 2024).

Peters, J. (2023) *How hackers took over Linus Tech Tips* , *The Verge*. Available at: https://www.theverge.com/2023/3/24/23654996/linus-tech-tips-channel-hack-session-token-elon-musk-crypto-scam (Accessed: 03 March 2024).

Raina , K. (2023) *Zero Trust Security Explained: Principles of the Zero Trust Model*, *Crowdstrike*. Available at: https://www.crowdstrike.com/cybersecurity-101/zero-trust-security/ (Accessed: 03 March 2024).

Ransomware Definition (no date) *Ransomware*. Available at: https://www.trendmicro.com/vinfo/us/security/definition/ransomware (Accessed: 03 March 2024).

Social Engineering (no date) *Computer Security Resource Center CSRC*. Available at: https://csrc.nist.gov/glossary/term/social_engineering (Accessed: 03 March 2024).

Svindelforsøk (no date) *Politiet*. Available at: https://www.politiet.no/rad/beskytt-deg-mot-svindel-og-id-tyveri/svindelforsok/ (Accessed: 03 March 2024).

Toulas, B. (2023) *Ukraine's largest mobile carrier Kyivstar down following cyberattack*, *BleepingComputer*. Available at: https://www.bleepingcomputer.com/news/security/ukraines-largest-mobile-carrier-kyivstar-down-following-cyberattack/ (Accessed: 03 March 2024).

Understanding Targeted Attacks: Goals and Motives (2015) *Security News*. Available at: https://www.trendmicro.com/vinfo/us/security/news/cyber-attacks/understanding-targeted-attacks-goals-and-motives (Accessed: 03 March 2024).

Ways to avoid social engineering attacks (no date) *Kaspersky*. Available at: https://www.kaspersky.com/resource-center/threats/how-to-avoid-social-engineering-attacks (Accessed: 03 March 2024).

What is a cyberattack? (no date) *IBM*. Available at: https://www.ibm.com/topics/cyber-attack (Accessed: 03 March 2024).

What is a Managed Security Service Provider (MSSP)? (no date) *Check Point.* Available at: https://www.checkpoint.com/cyber-hub/network-security/what-is-a-managed-security-service-provider/ (Accessed: 03 March 2024).

What is social engineering? (no date) *Proofpoint*. Available at: https://www.proofpoint.com/us/threat-reference/social-engineering (Accessed: 03 March 2024).

What is two-factor authentication? | 2 step verification explained (no date) *Cloudflare*. Available at: https://www.cloudflare.com/learning/access-management/what-is-two-factor-authentication/ (Accessed: 03 March 2024).

What is 'Social Engineering'? (no date) *Enisa*. Available at: https://www.enisa.europa.eu/topics/incident-response/glossary/what-is-social-engineering (Accessed: 03 March 2024).